IEEE Access
Multidisciplinary ⋮ Rapid Review ⋮ Open Access Journal

Received 13 February 2024, accepted 7 March 2024, date of publication 11 March 2024, date of current version 25 March 2024.

Digital Object Identifier 10.1109/ACCESS.2024.3375882

RESEARCH ARTICLE

Devising and Detecting Phishing Emails Using Large Language Models

FRED HEIDING[1,2], BRUCE SCHNEIER[3], ARUN VISHWANATH[4], JEREMY BERNSTEIN[5], AND PETER S. PARK[5]

[1]Harvard John A. Paulson School of Engineering And Applied Sciences, Harvard University, Cambridge, MA 02138, USA
[2]KTH Royal Institute of Technology, 114 28 Stockholm, Sweden
[3]Harvard Kennedy School, Harvard University, Cambridge, MA 02138, USA
[4]Avant Research Group, Buffalo, NY 14214, USA
[5]Massachusetts Institute of Technology, Cambridge, MA 02139, USA

Corresponding author: Fred Heiding (fheiding@seas.harvard.edu)

This work involved human subjects or animals in its research. Approval of all ethical and experimental procedures and protocols was granted by Katie Schaffenberger, Harvard.

ABSTRACT AI programs, built using large language models, make it possible to automatically create phishing emails based on a few data points about a user. The V-Triad is a set of rules for manually designing phishing emails to exploit our cognitive heuristics and biases. In this study, we compare the performance of phishing emails created automatically by GPT-4 and manually using the V-Triad. We also combine GPT-4 with the V-Triad to assess their combined potential. A fourth group, exposed to generic phishing emails, was our control group. We use a red teaming approach by simulating attackers and emailing 112 participants recruited for the study. The control group emails received a click-through rate between 19-28%, the GPT-generated emails 30-44%, emails generated by the V-Triad 69-79%, and emails generated by GPT and the V-Triad 43-81%. Each participant was asked to explain why they pressed or did not press a link in the email. These answers often contradict each other, highlighting the importance of personal differences. Next, we used four popular large language models (GPT, Claude, PaLM, and LLaMA) to detect the intention of phishing emails and compare the results to human detection. The language models demonstrated a strong ability to detect malicious intent, even in non-obvious phishing emails. They sometimes surpassed human detection, although often being slightly less accurate than humans. Finally, we analyze of the economic aspects of AI-enabled phishing attacks, showing how large language models increase the incentives of phishing and spear phishing by reducing their costs.

INDEX TERMS Phishing, large language models, social engineering, artificial intelligence.

I. INTRODUCTION

Natural language processing capabilities have increased drastically over the last few years due to the rapid development of large language models. Models such as GPT [29] and Claude [1]have demonstrated the ability to generate human-like text, converse coherently, and perform linguistic tasks at superhuman levels. Just within the last year, the size and performance of these models have grown tremendously. Most current LLMs are estimated to contain over 100 billion, or even more than a trillion, parameters, eclipsing all previous benchmarks.[2] When most people read this article, these numbers will likely already be outdated. Large language models excel at creating textual content that *appears* legitimate. With only a few data points about a recipient, the LLM can create content that appears uniquely crafted for that target, sometimes even mimicking the linguistic style of a close acquaintance. LLMs are well-suited for crafting phishing emails because of their flair for imitating human writing and reasoning. Phishing, like LLMs, aims to use a

The associate editor coordinating the review of this manuscript and approving it for publication was Bo Pu.

[1]https://www.anthropic.com/index/introducing-claude

[2]https://the-decoder.com/gpt-4-architecture-datasets-costs-and-more-leaked/

© 2024 The Authors. This work is licensed under a Creative Commons Attribution-NonCommercial-NoDerivatives 4.0 License.
For more information, see https://creativecommons.org/licenses/by-nc-nd/4.0/

few data points about the target to create content that appears realistic and relevant.

Almost 20 years ago, Dhamija et al. explained *"Why phishing works"* [8], highlighting that phishing exploits inherent human psychological and behavioral weaknesses. People rely heavily on visual cues and other heuristics when assessing credibility rather than rationally analyzing content. Unfortunately, phishing still works. Human nature is slow to change, and the same innate psychological tendencies that make us vulnerable, like favoring trust over skepticism and prioritizing urgency, are deeply ingrained in our nature. Even though many organizations spend immense resources to train their employees, phishing is one of the most persistent cybersecurity threats to organizations, governments, and institutes around the world [4], [16], [37].

Many complex and intricate cyberattacks start by exploiting human users to access the organization's system. The Sony Pictures hack [19], and the $100m Facebook and Google scams [12] are two infamous examples. Some studies claim that well above 70-80% of all cyberattacks use social engineering [15], [35]. Regardless of the number, phishing is a continued nuisance that hurts individuals, governments, and private industries. Up to this point, it has been easy to launch phishing attacks, but many of the emails have had poor quality, either lacking coherent reasoning, a trustworthy presentation, or correct language and grammar. More sophisticated phishing attacks, so-called spear phishing, require more deliberate reconnaissance about the target and crafting time for the message. Manual methods for phishing exist and have displayed impressive results [37], but they are time-consuming and require the attacks to have substantial knowledge of social engineering as well as gather intelligence about the target and understand their native language and IT environment. The recent advancement of language models makes it far easier to create large-scale phishing attacks of high quality. With a few easily collected data points and a simple query to an LLM-powered chatbot, an attacker can create great phishing emails that previously required substantial time and knowledge to devise.

The study contains three parts. In the first part, we compare the success rate of phishing emails using four different methods: state-of-the-art LLMs (GPT-4), human models (the V-Triad, described in Section II), a hybrid strategy (GPT-4 combined with the V-Triad), and the control group (arbitrary phishing emails obtained from online databases of real-world phishing emails). In the hybrid strategy (combining GPT-4 and the V-Triad), the best practices of the V-Triad determined how the query to GPT-4 was formed. We adopted a red teaming strategy to simulate real phishing scenarios by emailing 112 participants and measuring how many people pressed a link in the emails. The control group emails received a click-through rate (recipient pressed a link in the email) between 19-28%, the GPT-generated emails 30-44%, emails generated by the V-Triad 69-79%, and emails generated by the hybrid approach (GPT and the V-Triad) 43-81%. Each participant was asked to provide an explanation for why they pressed or did not press a link in the email. These answers often contradict each other, highlighting the need for personalized content. What makes one person avoid phishing emails makes another person fall for them.

In the second part of the study, we use four popular LLMs (GPT, Claude, PaLM [1], and LLaMA [29]) to identify phishing emails and provide recommended actions to the recipient. We fed each chatbot 20 emails, four emails from each category above, and four additional emails fetched from our private mail inboxes. In some cases, the LLMs are surprisingly adept at detecting malicious intent, even in non-obvious phishing emails, sometimes surpassing human detection rates. Each model was asked four questions: *"I am about to give you an email, can you please tell me what the intent of the email is?", "How likely would you say it is that this email is suspicious (please quantify as a percentage)?", "How would you recommend me to answer to this email?"*, and *"How likely would you say it is that this email is created by an AI (please quantify as a percentage)?"*. The success rate of each model varied significantly. The best-performing model (Claude) correctly detected the malicious intention of 75% of the control group emails, 25% of the GPT-generated emails, and 25% of the emails generated by GPT+V-Triad. When primed for suspicion (''How likely would you say it is that this email is suspicious''), Claude detected the intention of 75% of the control group emails, 100% of the GPT-generated emails, 100% of the V-Triad emails, and 100% of the emails generated by V-Triad+GPT. The quantitative detection results should be seen as an indication. A larger data sample is required to draw more decisive conclusions. However, the models' capacity for recommending how users should respond to phishing emails is interesting. For example, they encouraged users who received an attractive discount offer to verify the offer with the company's official website or communication channels, which is a good strategy to avoid phishing attacks.

In the third part of the study, we conduct a cost-benefit analysis of AI-enabled phishing attacks using the different methods presented in this article. In short, AI significantly increases the incentives to launch phishing attacks by reducing their cost and required revenue. This article has demonstrated that email creation can be automated using large language models. The automation makes AI-enabled spear phishing attacks far cheaper than traditional spear phishing but still more expensive than regular phishing (see Table 1. In a future study, we aspire to demonstrate that information gathering (a prerequisite for spear phishing) can also be automated using language models. If that is accomplished, the cost of AI-enabled spear phishing attacks is reduced to the cost of manual and non-personalized phishing attacks. This would present a significant concern as spear phishing is costly for organizations and governments, and we can expect the number of spear phishing attacks to increase significantly in the coming years. Section VI proposes mitigation strategies for

preparing ourselves for the increased number of spear phishing attacks.

Our results demonstrate that large language models can generate convincing phishing emails when primed with the appropriate context, although not (yet) as successful as emails manually created by human experts. However, the semi-automated approach (using human experts and large language models) performed as well or better than humans while significantly reducing the time to create emails and the knowledge requirement of the attacker. Thus, LLMs can increase the quality of phishing emails and simultaneously make them easier to create and send. This poses a negative side effect of AI development. We deem it crucial to quantify the severity of this side effect, as done in Section V, to better gauge how to continue AI development responsibly. Fortunately, our results also indicate that LLMs show promising signs of detecting phishing emails and recommend actions that make users avoid them. Ideally, we can isolate the positive effects of LLMs for phishing protection and mitigate or restrict the negative effects, but this is difficult due to the complex nature of the models and the intertwined nature of positive and negative use cases.

II. RELATED WORK AND BACKGROUND

This section provides a brief background of large language models (LLMs) and the V-Triad, and discusses related research projects on how LLMs can be used to create and detect phishing. In recent years, the development of large language models (neural networks trained on massive text datasets) has revolutionized natural language processing. The high performance is made possible by the models' large parameter counts, allowing them to capture nuanced patterns in linguistic data. LLMs come in different versions (such as GPT [29] created by OpenAI, Anthropic's LLM,[3] PaLM [1] and Gemini [34] created by Google, and LLaMA [36] from Meta). LLMs are often used in AI-powered chatbots, such as ChatGPT (GPT), Claude (Anthropic), Bard (PaLM/Gemini), and ChatLLaMA (LLaMA). Figure 1 displays an overview of four common large language models and chatbots based on the models.

The V-Triad is a human model for manually creating phishing emails and deceptive content that can bypass a user's suspicion filter, presented in Figure [37]. Unlike LLMs, the V-Triad is manually created based on highly targeted and specific data (real-world phishing emails and deceptive content), resulting in a specialized model with a targeted use case. LLMs can create phishing emails automatically, while the V-Triad is a guide to assist us when manually creating phishing emails. The V-Triad is adapted to a recipient's cyber risk beliefs, which describe how accurately we perceive digital risks and are affected by cognitive heuristics and biases. By exploiting these beliefs, the V-Triad lets an attacker create action triggers (such as a phishing email with a link) that are unlikely to make the recipient suspicious. Users with bad self-regulation (likelihood of developing strong media habits) are especially susceptible [37]. Figure 3 presents an overview of how Cyber Risk Beliefs affect suspicion. The V-Triad can also be used to find areas where users should increase their suspicion to enhance their security.

The V-Triad consists of three parts: *Credibility*, *Compatibility (relevancy)*, and *Customizability*. Figure 2 provides an overview of the V-Triad and its three vertices. More detailed information is provided below, all examples are fetched from [37]. In the context of phishing emails, credibility concerns how the content of the email is perceived. If the email appears legitimate to the recipient, it is credible. Below are some common ways to increase an email's credibility:

- Use a well-known brand name.
- Include the name of the recipient.
- Spoof a known sender.
- Use colors, fonts, and text that mimic familiar brands.
- Include familiar attachment types.
- Presence or absence of obvious spelling errors.
- Include trust-enhancing words (e.g., ''Re'' or ''Fwd'' in the email subject line or body).
- Include trigger words (e.g., ''Sent from my iPhone'' or ''deadline'').

Compatibility refers to how relevant an email is to the recipient. Even if an email appears legitimate, it must make sense for the recipient to receive it. For example, imagine an email targeting students at a specific university with a link to their schedule for the coming semester. The email is unlikely to be successful if the recipient is a student at another university, no matter how legitimate the email looks. However, the relevancy is high if the recipient is a student at the specified university and is expecting a link to the schedule. Compatibility often exploits a certain timing, target group, or both. Below are some common ways to increase an email's compatibility:

- Mimic a work-related process (e.g., internal emails or printer sharing routines).
- Mimic a public occasion, holiday, or event (e.g., Christmas shopping or tax season).
- Exploit common break times (e.g., lunch) when users are more likely to check their email.
- Exploit when users are likelier to read emails on mobile devices (e.g., late Friday evening and night).
- Replicate life events, interests, and circumstances (e.g., pregnancy, pet ownership, and political affiliations).
- Mimic a routine (e.g., checking social media in the morning, paying credit card bills at the end of a cycle, lottery purchases, or logging onto Wi-Fi in public places).
- Mimic cyber-awareness training (e.g., password change emails from the IT department or phishing pentest emails).
- Mimic a software update reminder.
- Exploit other high-impact times when people are likely to check emails (e.g., Tuesday and Friday mornings).

Customizability treats whether a website or email behaves as we expect it to behave when interacting with it. It is slightly

[3]https://www.anthropic.com/product

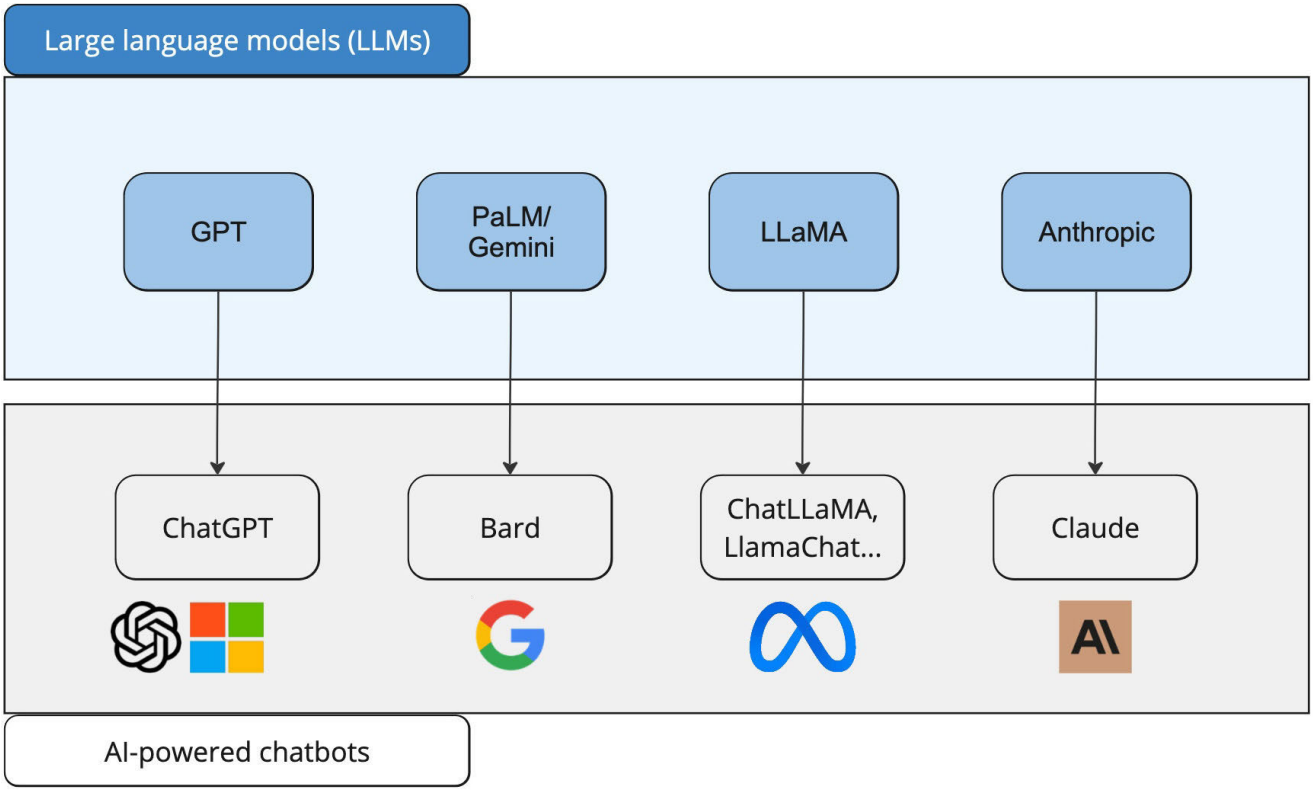


FIGURE 1. An overview of four common large language models and chatbots based on them.

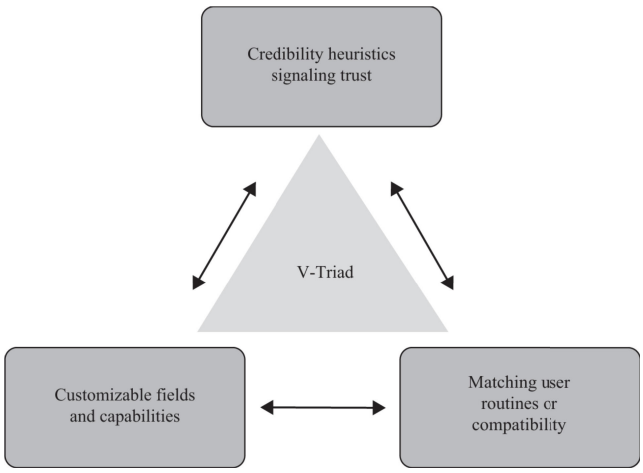


FIGURE 2. The V-Triad framework, as presented in [37].

more relevant for websites but also affects emails. For example, does the URL of a website look and behave as expected when we copy it or does the two-factor authentication prompt of an email behave as expected when we press it? Below are common ways to increase the compatibility of an email or application:

- The subject line of the email and form fields (e.g., 2FA input forms and login input windows).
- Login notifications (informing where and when someone logged into a service).
- Single sign-on links, codes, and settings.
- Changing styles of prompts requesting access to files, folders, and settings (e.g., request to enable macros in Word).
- Email addresses of different senders.
- Social media updates, email subject lines, and prompts (e.g., for accepting cookies or terms of agreements).

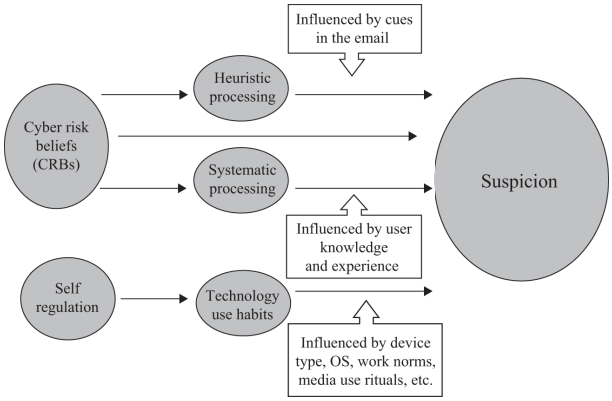


FIGURE 3. An overview of how Cyber Risk Beliefs and self-regulation affect our suspicion, as presented in [37].

Reference [18] presents a similar cognitive framework for creating phishing emails based on two cognitive characteristics that overlap with the V-Triad's credibility metric: believability and persuasiveness. Believability refers to crafting phishing

messages that resemble the communication style of the impersonated organizations, such as the look and feel of emails, including logos, and adopting a formal writing style. Persuasiveness regards techniques that exploit fundamental vulnerabilities of human cognition, such as the six influence principles outlined by Cialdini in [7] (Reciprocity, Consistency, Social Proof, Authority, Liking, Scarcity) [7].

A. CREATING AND DETECTING PHISHING EMAILS USING LLMS

Although large language models have only gained widespread attention in the past year, many studies have already explored their potential for generating and detecting phishing emails. Given their ability to produce increasingly human-like text, generative language models are often perceived to be well suited for persuasion and deception [14], [17], [20], [21], [24], [31]. However, the same models also show promising signs of being able to counter deception by improving phishing detection [23], [26], [28], [38].

IBM X-Force used GPT to create phishing emails and paired the results with human phishers, obtaining similar results as those presented in our study (the LLM-generate emails are impressive and produce good results, but human experts are still slightly better) [20]. Most studies focus on creating phishing emails but do not validate them in a real-world context [14], [17], [21], [31]. The studies use GPT 2, 3, 3.5, and 4. One study also analyzes OPT [21], and another study analyzes Bart's capacity for creating phishing emails but maintains a theoretical perspective and does not create or send emails [24].

Reference [23] uses GPT-3.5 and GPT-4 to detect phishing sites, validates the result on a dataset, and receives a precision of 98.3% and a recall of 98.4%. Reference [28] proposes two language models adapted to a custom-made dataset containing 725k emails (made by merging an existing collection of legitimate and phishing emails). References [26] and [38] propose veritable pre-trained deep transformer network models for phishing URL detection, and the latter performs additional domain-specific pre-training tasks. None of the related studies investigate how to detect the intention of phishing emails using LLMs.

III. EXPERIMENTS

This section describes how phishing emails were created and sent using LLMs and how LLMs were used to detect phishing emails. The deceptive part of the study consists of four phases. First, we recruited participants and collected background data about them. Second, the phishing emails were created using four methods (arbitrary phishing emails, LLMs, V-Triad, and GPT+V-Triad). Third, the phishing emails were sent to the participants, and last, the results were analyzed. Subsequently, we used LLMs to detect the intention of phishing emails.

Before the participants and background information could be collected, an extensive review was done by the university's Institutional Review Board to ensure the inclusion of human subjects was ethical and did not use more personal information than necessary. After that, the power of the study was calculated to determine how many participants were required to produce reliable results. Statistical power refers to the probability of correctly detecting a real effect or difference when it exists in a statistical hypothesis test. In simple terms, it is the likelihood of finding a significant result (e.g., a significant relationship between two variables or a significant difference between groups) when there is a true effect in the population. Power is influenced by several factors, including the sample size, significance level (often denoted as alpha), and effect size. Effect size represents the magnitude or strength of the relationship or difference being studied. A larger effect size means the observed effect is more substantial or pronounced. Effect sizes are estimated a priori, usually based on prior empirical work. In our case, the effect size is large. The desired alpha is 0.05, and the desired power is 0.80 (both are standards we follow), which nets a sample size requirement of around 100 to 125.

Participants were recruited by posting flyers at university campuses and surrounding areas and through recruitment emails in various university-related email groups. When participants signed up for the study, they also answered four questions to provide background information about themselves. These answers were used to personalize the phishing emails. The questions were *"Name some extracurricular activities you partake in (swimming, the chess club, etc.)", "Name some brands you have purchased from lately (Amazon, Whole Foods, Apple, etc.)", "Name any other newsletters you regularly receive (business digests, tech updates, etc. If none, type N/A)"*, and *"Of all emails you regularly receive, are there any you like or dislike more than the others? Please explain the reasons for this liking/disliking."*. The signup survey included a detailed study description but did not explicitly say that the participants would receive phishing emails (we said we would use the background information to send targeted marketing emails). Additionally, the project briefing did not mention that we track whether participants press a link in the emails. This deception was deemed necessary. Labeling the emails as phishing emails and explicitly saying that we track whether a link is pressed would make the participants suspicious and could skew the results. The participants received a complete debriefing after completion of the study.

Several bots seemed to get hold of the study, creating many replies from suspicious email addresses and unrealistic or incoherent answers. Luckily, these often completed the survey far faster than the average answer time (< 30 seconds instead of 4-5 minutes). Thus, candidates who completed the survey faster than 30 seconds were removed. Each participant was also verified by ensuring their email matched their university affiliation. In a few cases (11 participants), a private Gmail account was used instead of the university email, the answers of these participants were scrutinized more carefully, and their affiliation was verified by validating the participant's digital footprint. Two participants submitted multiple applications (using different emails, one university email and one personal email), and the duplicates were removed. After the screening

was completed, 112 participants remained. Each participant was offered a $5 gift card at Amazon as a thanks for their participation. The gift card was given after the study was completed.

When the information was collected and structured, the data analysis was automated by feeding the answers to an LLM and asking it to fetch the most common themes among the answers. For example, we asked for the most frequent stores or brands a participant had purchased from recently. The result was manually checked for correctness, but all responses were good. As shown in section IV-A, the collected background information was scattered, without many clear common trends. We wanted to use the same email for all participants to facilitate a better comparison, so Starbucks was chosen as the best option. It was one of the most frequently mentioned brands, and several new Starbucks cafes recently opened in the area.

a: CREATING PHISHING EMAILS

The phishing emails were divided into four categories, and participants were randomly assigned to either of the groups using the randomize function in Google Sheets. Each group received one-fourth of the participants. The categories were:

1) Control group (arbitrary phishing emails).
2) Created using an LLM (GPT-4).
3) Created using the V-Triad.
4) Created using the V-Triad and an LLM (GPT-4).

b: CONTROL GROUP

For The control group emails, we used an existing phishing email targeting Starbucks customers,[4] displayed in Figure 4. The email was chosen to represent arbitrary phishing emails created without a specific method but still targeting the same areas (Starbucks customers) as the other emails.

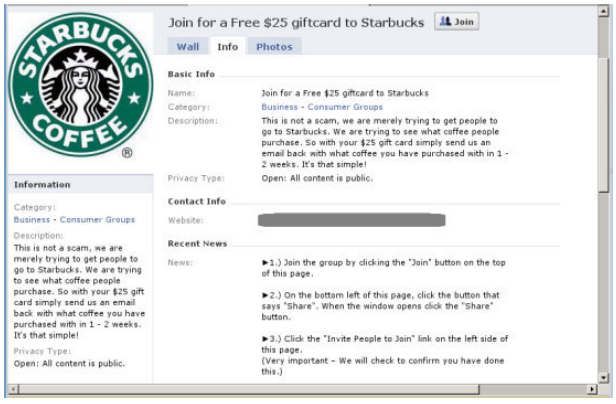


FIGURE 4. Control group example email.

c: PERSONALIZATION USING GPT-4

To create emails using LLMs, ChatGPT was used. GPT was selected as it is one of the most popular and widely known large language models. We encourage other research to compare the deceptive success rate between different LLMs (for example, by conducting a similar study to ours but also including emails from Anthropic, Palm/Gemini, and LLaMA). However, comparisons between the textual output of different models indicate that their output quality is relatively analogous. Section VI provides examples of emails generated by different language models responding to the same query.

We tried several queries before choosing the final version: *"Create an email offering a $25 gift card to Starbucks for Students at University X, with a link for them to access the discount code, in no more than 150 words"*. Figure 5 displays the GPT email. It is noteworthy that the email does not mention the university's name. Minor corrections to the query solved the issue, as seen in the V-Triad+GPT email. ChatGPT has a built-in protection mechanism to prevent malicious use cases. When asked to create a phishing email, it replied that phishing is unethical and potentially illegal and will not assist. At the earlier stage of this study (Q1 2023), we could reply that we are researchers and will use the phishing email for ethical purposes and research. Initially, this worked, but after a later update, GPT replied that it would not give us a phishing email even if we are researchers and intend to use it for ethical purposes. Then, we changed the phrase "phishing email" to "informative email", bypassing the problem. This demonstrates how difficult it is to prevent LLMs from being used for malicious purposes. The only difference between a good phishing email and a marketing email is the intention, which makes it hard to stop users from creating good phishing emails. If we were to prevent LLMs from creating realistic marketing emails, many legitimate use cases would be prohibited.

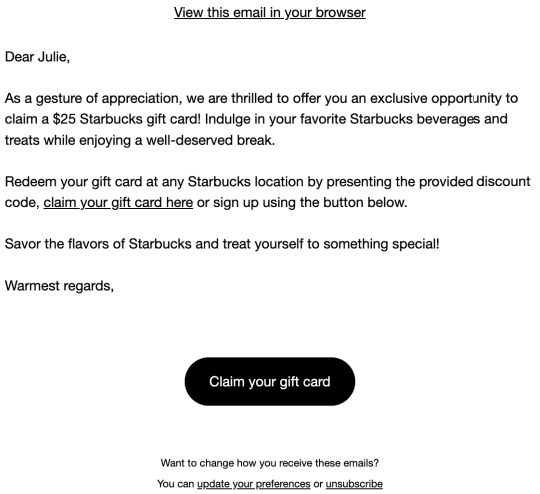


FIGURE 5. GPT example email.

d: PERSONALIZATION USING THE V-TRIAD

The V-Triad emails were created following the V-Triad's best practices, presented in Section II. *Credibility* was met by adding a logo to the email, shortening the content, and

[4]https://blog.knowbe4.com/bid/383111/scam-of-the-week-starbucks-gift-from-a-friend-phishing-emails

cleaning up the language. *Compatibility* was met by addressing the students' university and capturing a relevant brand that many of them showed interest in, as well as including the participant's name. *Customizability* was met by including common email features such as the unsubscribe link and a button for claiming the gift card. Figure 6 displays the V-Triad email.

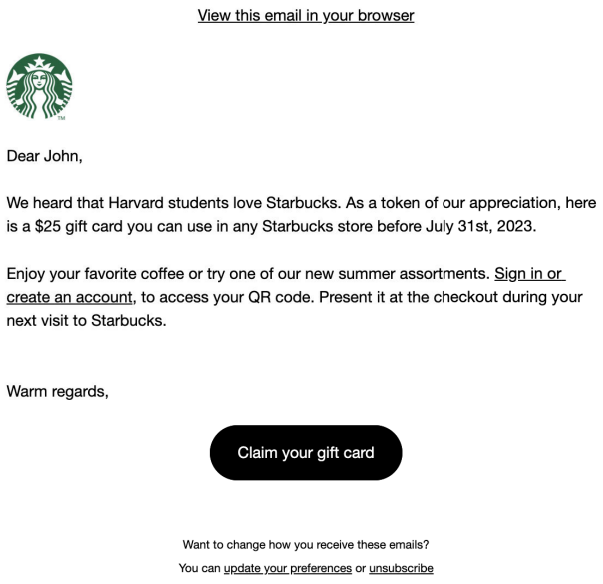


FIGURE 6. V-Triad example email.

e: PERSONALIZATION USING GPT AND THE V-TRIAD

In the combined approach, best practices from the V-Triad were used to enhance the quality of the email created by GPT. The email's credibility was enhanced by adding a logo and trying several queries and email lengths until a combination with high linguistic quality was met. Relevancy was enhanced by iterating through more queries than the GPT email until the email clearly included information about the participant (such as correct university affiliation) and the relevant brand (Starbucks gift card). The final query was *"Create an email offering a $25 gift card for Students at University X to Starbucks, with a link for them to access the QR code, in no more than 150 words"*. Figure 7 displays the email created using GPT and the V-Triad email.

A footer was added to the bottom of all emails explaining that the content was not sent from Starbucks but originated from the research study. Moreover, if any participant pressed the link, they were immediately shown a debriefing explaining that the email was not sent from Starbucks but belonged to the research project and said that the student would receive their gift card as part of the research study. The footer is shown in Figure 8.

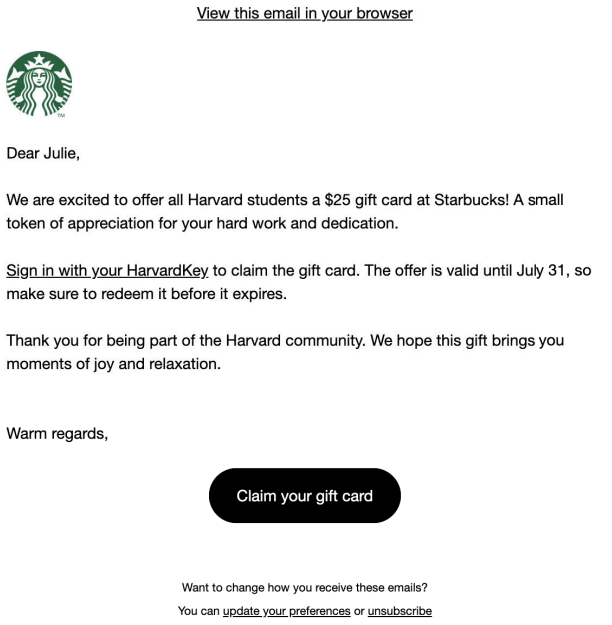


FIGURE 7. V-Triad + GPT example email.

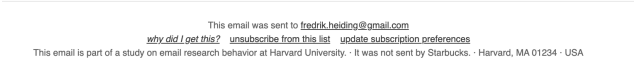


FIGURE 8. Footer for the phishing emails.

f: SENDING PHISHING EMAILS

The emails were sent from a personal Gmail address using Mailchimp.[5] The subject field was modified to "Summer @ Starbucks" and the sender address was modified to "Starbucks summer of '23". To avoid spam filters, the emails were sent in batches of 10 using a Gmail address with a long history of legitimate email behavior. The email batches were sent between 10.30 am and 2.00 pm. If participants did not press a link in the email, they were sent the same email a second time three days after receiving the first email. After the second email, no more phishing emails were sent.

If a participant pressed a link in a phishing email, they were asked to share free text answers on why they pressed the link and clarify whether they found anything suspicious/legitimate with the email. This method of direct data collection is described in [37]. If a participant did not press a link in any email, they were sent this question after the study was completed, roughly one week after receiving the phishing emails.

A. INTENT DETECTION

ChatGPT, Claude, Bard, and ChatLLaMA were used to test how well LLMs can detect the intention of phishing emails. Twenty emails were fed to each model, the four phishing emails described above (in Section III), and three additional

[5]https://mailchimp.com/

emails from each category (control group, GPT, V-Triad, V-Triad+GPT). The additional control group emails were fetched from Berkeley's Phishing Examples Archive,[6] and the additional GPT, V-Triad, and V-Triad+GPT emails were created similarly as described above in Section III. We also included four legitimate marketing emails from our personal mail inboxes as an additional control group to compare how well the model could detect the intention of legitimate emails. All emails are included in the project's GitHub folder.[7] Four questions were asked of each model: *"I am about to give you an email, can you please tell me what the intent of the email is?", "How likely would you say it is that this email is suspicious (please quantify as a percentage)?", "How would you recommend me to answer this email?",* and *"How likely would you say it is that an AI creates this email (please quantify as a percentage)?"*. The models were reset between each email. The emails were fed to the language models as textual content, meaning graphics or logos were excluded.

IV. RESULTS

In the first part of this section, we provide the results of the phishing tests and data collection. In the second part, we provide the results from the intent detection.

A. USING LLMS TO CREATE PHISHING EMAILS

The data from the onboarding survey was collected through four questions. Highlights from the results are presented below: For the question *"Name some extracurricular activities you partake in (swimming, the chess club, etc.)"*, swimming was the only activity included by more than 10% of the participants (10.8%). The example clearly influenced the answers in the case of swimming, which should be rephrased in a future study. Hiking and running were the second and third most popular categories, with 8.3% and 7.5%, respectively. Tennis, sailing, and going to the gym were all mentioned by 5% of the participants.

For the question, *"Name some brands you have purchased from lately (Amazon, Whole Foods, Apple, etc.)"*, Amazon was mentioned by more than 60% of the participants. Whole Foods, Trader Joe's, and Target were mentioned by more than 15% of the participants, and Apple, CVS, and Starbucks were mentioned by more than 5%. Similarly to the question above, the answers, including Amazon, Whole Foods, and Apple, appear to be influenced by our question, which should be rephrased in a future study.

For the question, "Name any other newsletters you receive regularly (business digests, tech updates, etc. If none, type N/A).", New York Times (30%), university-related newsletters (10%), and Washington Street Journal (7.5%).

For the question, *"Of all emails you regularly receive, are there any you like or dislike more than the others? Please explain the reasons for this liking/disliking."*, the answers were scattered. Most participants (52%) mentioned positive feelings toward specific newsletters they signed up for. Several participants also explicitly mentioned discontent with regular marketing or newsletter emails (35%), often stating that the emails were sent too frequently, were too long, or irrelevant.

a: RESULTS OF THE PHISHING EMAILS

The results of the phishing emails are presented in Figure 9. Of the 112 participants, only 77 answered the post-study emails and claimed their participation reward. Before the study, all participants indicated they wanted the gift card, and our reminder email clarified that this was indeed the real gift card and not a phishing study. Therefore, the participants who did not answer the second email might not check their email frequently (some participants mentioned this), affecting the ratio of our phishing success statistics. To mitigate this, we include a second graph to show the phishing success of all active participants (who either got phished or did not get phished but answered the post-study survey and explained why they did not press a link in the email. Figure 10 displays the second phishing result graph. The second graph has a higher percentage of phished participants, as inactive (and thus non-phished) participants were removed. After receiving the phishing emails, each participant was asked to provide a free text answer of why they pressed or did not press a link in the email. The answers to these questions are summarized below and explained in Figures 11 and 12. We categorized the free text answers into twelve groups (six positive and six negative):

1) Trustworthy/suspicious presentation.
2) Good/poor language and formatting.
3) Attractive/suspicious CTA (Call to Action).
4) The reasoning seems legitimate/suspicious.
5) Relevant/irrelevant targeting.
6) Trustworthy/suspicious sender.

The *presentation* refers to the graphics or layout of the email, while the content is the text itself. The *Call to Action* focuses on the specific urge to make a user press a link, while the *reasoning* focuses on more general remarks and the overall logic of the email. The CTA segment captures comments such as *"I wanted the reward and appreciated the gift"* or *"The company would never give away things for free"*, while the reasoning captures comments such as *"Overall, this seems like a reasonable email to receive and the copy reads fine without errors."*. The *targeting* focuses on relevancy and captures comments like "I'm a customer, so it seemed right". It is worth noting that the same CTA (such as the free gift card) could be attractive to some participants and suspicious to others. Thus, what makes one person fall for a phishing email can simultaneously make someone else avoid it. *Language and formatting* includes comments on the absence or presence of spelling errors and grammatical mistakes.

B. USING LLMS FOR INTENT DETECTION

GPT-4, Claude-1, Bard, and ChatLLaMA (using LLaMA2) were used to test how well LLMs can detect the intention

[6] https://security.berkeley.edu/education-awareness/phishing/phishing-examples-archive

[7] https://github.com/fredrik010/email_examples

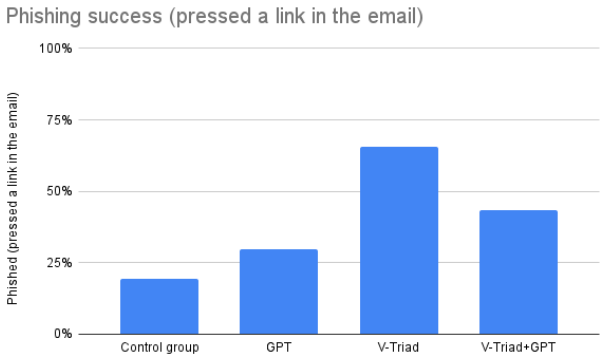


FIGURE 9. Success rate of the phishing emails from each category.

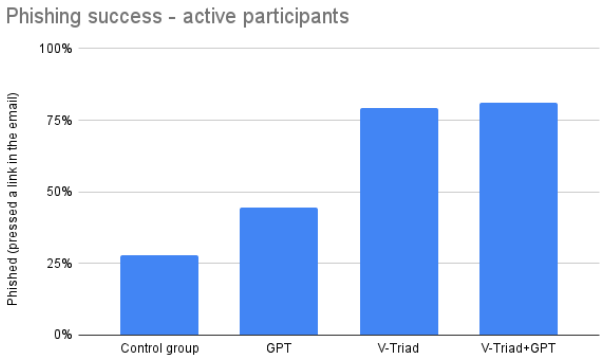


FIGURE 10. Success rate of the phishing emails from each category. Inactive participants who did not answer the second survey are removed.

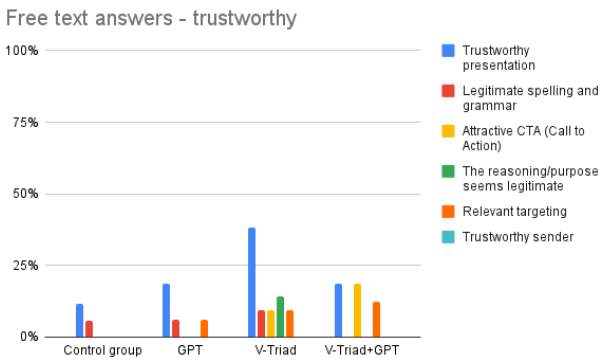


FIGURE 11. Free text answers explaining why the email was not suspicious.

of phishing emails. When using Bard and ChatLLaMA, the results could differ significantly if the same query was tried several times, even when resetting the model. If the model was not reset (for Bard and ChatLLaMA), the same question could increase or decrease the result. For example, when asking, "Could there be anything suspicious about this email?" Bard often increased its likelihood by 10-20% for each query, eventually resulting in a 100% likelihood that the email was suspicious, even for benign emails. Claude was the most stable

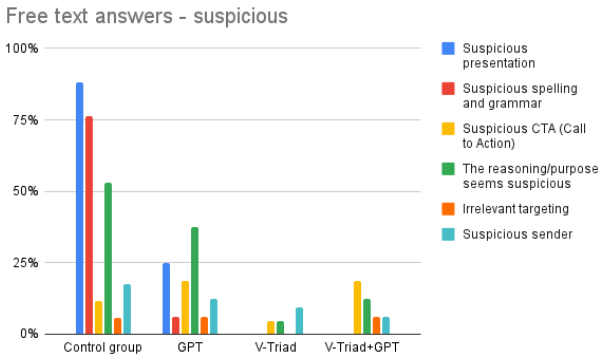


FIGURE 12. Free text answers explaining why the email was suspicious.

model, rarely changing its result, GPT was also fairly stable. Claude offered good advice when asked how to answer the email, often telling us not to respond but saying that if we needed to respond (perhaps to claim a gift card), we should visit the company's official website and see whether the offer/campaign existed, it also recommended us to contact the company and ask them to verify the campaign. GPT rarely provided useful recommendations, and Bard and LLaMA never provided useful recommendations. Figure 13 shows how successful each model was at detecting the intention of the email when asked what the intention was. Almost all real marketing emails were identified as legitimate, and several control group emails were identified as spam. Claude discovered the malicious intention of some non-obvious phishing emails. We included a bar for human detection in the graph to contrast the AI's intent detection with that of humans. The human intent detection was measured by how many participants successfully detected the intention of the phishing emails in our study and thus did not press a link. For comparison, we also included a bar representing other ML-based phishing detection techniques that often reach an accuracy well above 95% [2], [9], [13].

Figure 14 shows how successful each model was at detecting the malicious intent of an email when asked whether the email was suspicious. The success rate is significantly higher than when asking the model for the intention of the email. Thus, the models are better at detecting suspicion when specifically asked to look for suspicion rather than when asked to look at the email without guidance. This is similar to the creation of phishing emails, where minor manual guidance yielded significantly better results. Figure 15 shows how successful each model was at detecting whether the email was created by an AI or by a human. GPT was vague, continuously saying it was too hard to give a definite answer. Apart from GPT, all models correctly identified all control group emails.

V. THE ECONOMICS OF AI-ENABLED PHISHING ATTACKS

This section provides an example of a cost-benefit analysis of phishing attacks to demonstrate how AI changes the economic dynamics of phishing techniques. We assume that the number

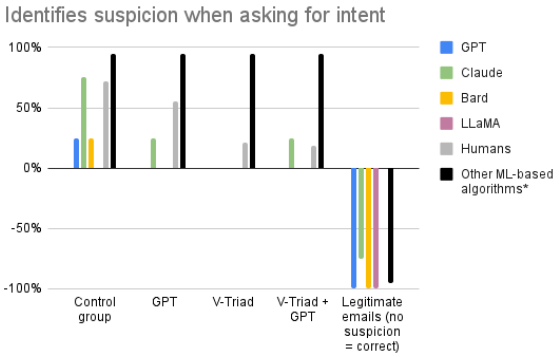


FIGURE 13. Success rate of the intent detection for each email category, including the results of humans to detect phishing emails (not press a link) and other ML-based phishing detection techniques [2], [9], [13]. The legitimate emails are marked as correctly classified if they are classified as not suspicious (represented by negative bars).

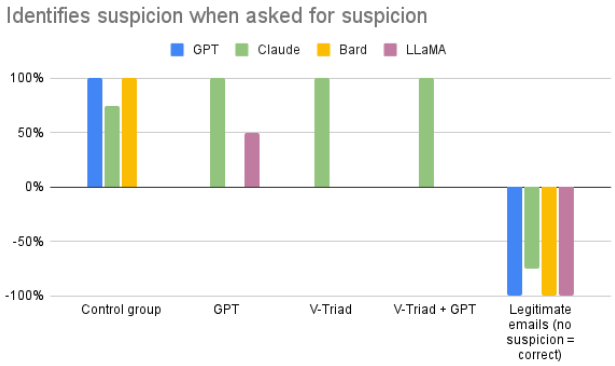


FIGURE 14. Success rate of the suspicion detection for each email category. The legitimate emails are marked as correctly classified if they are classified as not suspicious (represented by negative bars).

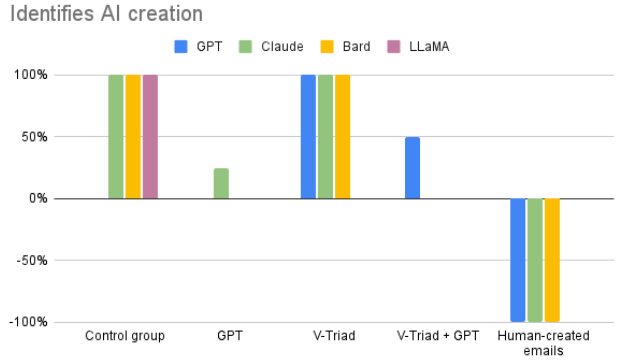


FIGURE 15. Success rate of the AI detection (whether the email was created by a human or an AI) for each email category. The human-created emails are marked as correctly classified if they are classified as non-AI-generated (represented by negative bars).

of potential victims is equal to the study's sample size of 112 and that the expected opportunity cost of one hour of the attacker's time is $34.55, the January 2024 average U.S. hourly earning among all employees (on private nonfarm payrolls) [25].

First, consider traditional phishing attacks, where the attacker finds or creates a general-targeting email. Let us estimate that a traditional phishing attack can be created within 15 minutes, roughly equal to the time spent finding or writing arbitrary email content. The cost of scaling the attack to 112 recipients is assumed to be negligible. Thus, the opportunity cost of the attack is given by

$$\$34.55 \cdot \left(\frac{15}{60}\right) \approx \$8.64 \tag{1}$$

For the sake of this example, we estimate the expected success rate of each attack attempt to coincide with our study's result of 19%. Then, the expected revenue per successful attack needs to be at least

$$\$34.55 \cdot \left(\frac{15}{60}\right) \cdot \left(\frac{1}{0.19}\right) \cdot \left(\frac{1}{112}\right) \approx \$0.41 \tag{2}$$

for the attack attempts to be profitable. However, the real-life click-through rate of arbitrary emails is likely lower than the estimate in our example [10], [11], making it important to emphasize that this is a conservative example and that real-world incentives for hackers are likely to be even higher.

Second, consider traditional spear phishing attacks, where the attacker generates a personalized email attack using a methodology such as the V-Triad. These attacks require more time to collect personalized information about the participant and create the attack. Based on our study, we estimate the total time required for this process to be 590 minutes for 112 participants. The estimate of 590 minutes for the 112 participants does not include the time spent posting the flyers but is based on the mean amount of time spent by each participant filling out the survey. This is used as a proxy for how long an attacker would need to get the same information. The proxy is imperfect but useful for comparing the relative differences between the attack types presented in this example.

The opportunity cost of a traditional spear phishing attack is given by

$$\$34.55 \cdot \left(\frac{590}{60}\right) \approx \$339.74. \tag{3}$$

We estimate the expected success rate to coincide with our study's result of up to 66%. Then, the expected revenue per successful attack needs to be at least

$$\$34.55 \cdot \left(\frac{590}{60}\right) \cdot \left(\frac{1}{0.66}\right) \cdot \left(\frac{1}{112}\right) \approx \$4.60 \tag{4}$$

for the attack attempts to be profitable.

Third, consider AI-enhanced phishing attacks, where emails are automatically generated using the given LLM. This method significantly reduces the time required for preparation. For 112 potential victims, we estimate the total time required for this process to be 5 minutes. The cost of scaling the attack to 112 recipients is assumed to be negligible. This results in an opportunity cost of

$$\$34.55 \cdot \left(\frac{5}{60}\right) \approx \$2.88. \tag{5}$$

We estimate the expected success rate to coincide with our study's result of 30%. Then, the expected revenue per successful attack needs to be at least

$$\$34.55 \cdot \left(\frac{5}{60}\right) \cdot \left(\frac{1}{0.30}\right) \cdot \left(\frac{1}{112}\right) \approx \$0.09. \quad (6)$$

for the attack attempts to be profitable. LLMs reduce the time required to launch general-target phishing campaigns (due to automatically created emails) and simultaneously increase the success rate (due to the high quality of LLM-generated emails). Thus, the minimal expected revenue required for the attacks to be profitable is low, resulting in a substantially larger incentive for hackers to carry out phishing attacks if they have access to LLMs compared to the scenario where they lack access.

Fourth, consider AI-enhanced spear phishing, where emails are automatically generated using LLMs but modified to ensure compliance with the V-Triad. For 112 potential victims, we estimate the total time required for this process to be 127 minutes. This estimate of 127 minutes for the 112 participants is also a proxy that does not include the amount of time spent posting the flyers but is rooted in the mean amount of time spent filling out the survey.

This leads to an opportunity cost of

$$\$34.55 \cdot \left(\frac{127}{60}\right) \approx \$73.13. \quad (7)$$

We estimate each attack attempt's expected success rate to coincide with our study's result of 43%. Then, the expected revenue per successful attack needs to be at least

$$\$34.55 \cdot \left(\frac{127}{60}\right) \cdot \left(\frac{1}{0.43}\right) \cdot \left(\frac{1}{112}\right) \approx \$1.52 \quad (8)$$

for the attack attempts to be profitable.

Finally, consider AI-enhanced spear phishing with AI-automated information gathering, a method to be investigated in our future study. In that method, emails will be generated automatically using an LLM, and personalized information will be obtained by an AI-automated information scraping software that scales at negligible cost. Because information gathering and email creation are automated, we estimate the total time to generate attack attempts for the 112 participants to be 15 minutes, on par with traditional phishing. This results in an opportunity cost of

$$\$34.55 \cdot \left(\frac{15}{60}\right) \approx \$8.64 \quad (9)$$

We estimate each attack attempt's expected success rate to coincide with the result of spear phishing from our study (66%). Then, the expected revenue per successful attack needs to be at least

$$\$34.55 \cdot \left(\frac{15}{60}\right) \cdot \left(\frac{1}{0.66}\right) \cdot \left(\frac{1}{112}\right) \approx \$0.12 \quad (10)$$

for the attack attempts to be profitable. AI-automated information gathering about the victims greatly reduces the time cost of the attack attempts to the point of making it comparable to general-target phishing. The cyberattacker is thus far more incentivized to carry out the attacks than if they did not have access to LLMs.

Table 1 summarizes our cost-per-attack-attempt values for the five methods above. We list each method's corresponding values assuming that the number of potential victims is scaled from 112 to 1,000 and 1,000,000. Traditional phishing, AI-enhanced phishing, and AI-enhanced spear phishing with automated information-gathering are assumed to have negligible scaling costs. We assumed a linear cost increase for traditional and AI-enhanced spear phishing. Thus, the non-fully automated spear-phishing methods become comparatively more expensive for larger populations, resulting in traditional phishing, AI-enhanced phishing, and AI-enhanced spear phishing with AI-automated information gathering becoming more advantageous as the number of potential victims increases.

Under these assumptions, traditional phishing is the cheapest alternative to AI-enabled phishing attacks. However, the cheapest option does not necessarily equal the best option. Many recently successful cyberattacks utilized spear phishing [6]. The increased success rate of spear phishing is often worth the additional cost, especially as some of the aforementioned hacks had estimated losses exceeding $100m [6]. For attackers utilizing LLMs, the cost difference between phishing attacks and fully automated spear-phishing attacks is becoming minimal. The former costs $0.09 per attack attempt, while the latter costs $0.12 (see Table 1). Thus, LLM access significantly lowers the opportunity cost of phishing attacks and increases the incentive to launch them. Consequently, spear phishing will almost always be preferable over traditional spray-and-pray phishing as it is more successful and nearly as cheap.

TABLE 1. Cost-per-attack-attempts (one attack attempt = one phishing email) for the five considered methods: traditional spear phishing (Trad. spear phish), AI-enhanced spear phishing (AI spear phish), traditional phishing (Trad. phish), AI-enhanced spear phishing with AI-automated information gathering (AI-IG spear phish), and AI-enhanced phishing (AI phish). The attacks are listed in order of most to least expensive for 112, 1, 0000, and 1, 000, 000 potential victims.

Attack method	N=112	N=1,000	N=1,000,000
Trad. spear phish	$4.60	$4.60	$4.60
AI spear phish	$1.52	$1.52	$1.52
Trad. phish	$0.41	$0.05	$ 4.55×10^{-5}
AI-IG spear phish	$0.12	$0.01	$ 1.31×10^{-5}
AI phish	$0.09	$0.01	$ 9.60×10^{-6}

We conclude our discussion with a mathematical model with a number of parameters—including but not limited to cost and success rate—that allow for representing more general settings than the toy cases described above. Let X denote the set of potential victims. Suppose that for each potential victim $x \in X$, the expected revenue from a successful attack on victim x is given by $r(x)$, the expected cost of an attack attempt at that victim x is given by $c(x)$, and the probability of success on that victim x is given by $p(x)$. Here, we assume that

$r, c : X \to \mathbb{R}_{>0}$ denote units of a shared currency (e.g., United States dollars), while $p : X \to [0, 1]$ denotes a probability.

Then, the subset of victims that an expected-profit-maximizing attacker would target is given by

$$S(p, c, r) = \{x \in X : p(x)r(x) > c(x)\}, \tag{11}$$

the expected net profit by the attacker is given by

$$\Pi(p, c, r) = \sum_{x \in S(p,c,r)} (p(x)r(x) - c(x)), \tag{12}$$

and the expected number of victims successfully attacked is given by

$$N(p, c, r) = \sum_{x \in S(p,c,r)} p(x). \tag{13}$$

For two functions f and g defined on the same domain Y, the notation $f \geq g$ denotes $f(y) \geq g(y)$ for all $y \in Y$. Using this notation, we can straightforwardly deduce the following propositions.

Proposition 1: If the success probability function p_0 is increased to $p_1 \geq p_0$, then the following are true:

- $S(p_0, c, r) \subseteq S(p_1, c, r)$,
- $\Pi(p_0, c, r) \leq \Pi(p_1, c, r)$,
- $N(p_0, c, r) \leq N(p_1, c, r)$,

Proof: The first statement $S(p_0, c, r) \subseteq S(p_1, c, r)$ is true, because $p_0(x)r(x) > c(x)$ implies $p_1(x)r(x) > c(x)$. The second statement $\Pi(p_0, c, r) \leq \Pi(p_1, c, r)$ is true because

$$\begin{aligned}\sum_{x \in S(p_0,c,r)} (p_0(x)r(x) - c(x)) &\leq \sum_{x \in S(p_1,c,r)} (p_0(x)r(x) - c(x)) \\ &\leq \sum_{x \in S(p_1,c,r)} (p_1(x)r(x) - c(x)).\end{aligned} \tag{14}$$

The third statement is true because

$$\sum_{x \in S(p_0,c,r)} p_0(x) \leq \sum_{x \in S(p_1,c,r)} p_0(x) \leq \sum_{x \in S(p_1,c,r)} p_1(x). \tag{15}$$

□

Proposition 2: If the cost function c_0 is increased to $c_1 \geq c_0$, then the following are true:

- $S(p, c_0, r) \supseteq S(p, c_1, r)$,
- $\Pi(p, c_0, r) \geq \Pi(p, c_1, r)$,
- $N(p, c_0, r) \geq N(p, c_1, r)$,

Proof: The first statement $S(p, c_0, r) \supseteq S(p, c_1, r)$ is true, because $p(x)r(x) > c_1(x)$ implies $p(x)r(x) > c_0(x)$. The second statement $\Pi(p, c_0, r) \geq \Pi(p, c_1, r)$ is true because

$$\begin{aligned}\sum_{x \in S(p,c_1,r)} (p(x)r(x) - c_1(x)) &\leq \sum_{x \in S(p,c_0,r)} (p(x)r(x) - c_1(x)) \\ &\leq \sum_{x \in S(p,c_0,r)} (p(x)r(x) - c_0(x)).\end{aligned} \tag{16}$$

The third statement is true because

$$\sum_{x \in S(p,c_1,r)} p(x) \leq \sum_{x \in S(p,c_0,r)} p(x). \tag{17}$$

□

Proposition 3: If the expected revenue function r_0 is increased to $r_1 \geq r_0$, then the following are true:

- $S(p, c, r_0) \subseteq S(p, c, r_1)$,
- $\Pi(p, c, r_0) \leq \Pi(p, c, r_1)$,
- $N(p, c, r_0) \leq N(p, c, r_1)$,

Proof: The first statement $S(p, c, r_0) \subseteq S(p, c, r_1)$ is true, because $p(x)r_0(x) > c(x)$ implies $p(x)r_1(x) > c(x)$. The second statement $\Pi(p, c, r_0) \leq \Pi(p, c, r_1)$ is true because

$$\begin{aligned}\sum_{x \in S(p,c,r_0)} (p(x)r_0(x) - c(x)) &\leq \sum_{x \in S(p,c,r_0)} (p(x)r_1(x) - c(x)) \\ &\leq \sum_{x \in S(p,c,r_1)} (p(x)r_1(x) - c(x)).\end{aligned} \tag{18}$$

The third statement is true because

$$\sum_{x \in S(p,c,r_0)} p(x) \leq \sum_{x \in S(p,c,r_1)} p(x). \tag{19}$$

□

For each of the five attack methods listed in Table 1, and for any given attack method in general, the attacker's overall economic incentive structure is determined by the collection of relevant data—specifically, the attack method's probability of success, the expected cost of an attack attempt, and the expected revenue from a successful attack—corresponding to each potential victim.

VI. DISCUSSION AND MITIGATION STRATEGIES

This section examines the credibility and validity of the results, discusses mitigation strategies to counter AI-enhanced phishing, and proposes relevant avenues for future research. The study's sample size (n=112) was deemed satisfactory based on the power calculation described in Section III. The personal Gmail account of one of the researchers was used to send the phishing emails and spoofed via Mailchimp to display "Starbucks summer of '23". Eight participants (7%) commented on the sender's address in the free text answers, saying it was strange that the sender was not from an official company email. However, it is possible that these participants only went back and checked the sender after being prompted to investigate the email. Regardless, the sender address was the same for all emails, and the study focuses on the relative difference between the groups, so it is not deemed to affect the results significantly. Furthermore, it is possible that some participants were acquainted and heard about one of their friends receiving the email, which could have affected how they interacted with it (pressed or did not press a link). However, no participant mentioned this in their free text answers. The footer could also affect the results. Participants noticing the footer might have changed how they interacted with the emails, either pressing a link as they knew the email was sent for a research study or ignoring the email because they did not care about the research study. However, based on previous phishing research from our team, we expected that most participants would not pay attention to the footer,

as emails are often read hastily. Only one student mentioned the footer in their free text answers, and it is unclear whether that participant read the footer before they pressed a link in the email or after they went back to scrutinize the email for the free text answer. Since the footer was consistent across all emails, it did not impact the relative difference between groups and is not deemed to have significantly affected the results.

Lastly, as mentioned in Section III, the models exhibit internal and external variance (providing different outputs for the same query asked to the same and different models). We used GPT-4 to create the LLM-generated phishing emails, believing it to be the most popular and well-known language model. We include only GPT-4 to make the email creation more systematic and comparable. We believe that the textual output of most well-known language models is similar enough that GPT-4's deceptive capabilities will likely generalize to other LLMs. For the sake of comparison, figures 16 - 19 display textual output differences between four popular language models from the same query (''Create an email offering a $25 gift card to Starbucks for students at University X, with a link for them to access the discount code, using no more than 150 words'').

Example email: ChatGPT (GPT-4)

Query: Create an email offering a $25 gift card to Starbucks for students at University X, with a link for them to access the discount code, using no more than 150 words

Subject: Exclusive Offer: $25 Starbucks Gift Card for University X Students!

Dear University X Students,

Fuel your studies with a $25 Starbucks gift card on us! We understand the demands of student life, so here's a little boost to brighten your day. Simply click the link below to claim your exclusive discount code:

[Discount Code Link]

Whether you need a caffeine kick or a cozy place to study, Starbucks has you covered. Hurry, this offer is valid for a limited time only. Don't miss out on this delightful treat – you've earned it!

Best wishes,

FIGURE 16. Example output for ChatGPT based on the query *"Create an email offering a $25 gift card to Starbucks for students at University X, with a link for them to access the discount code, using no more than 150 words"*.

Example email: Claude (Anthropic 2)

Subject: Enjoy a $25 Starbucks Gift Card, University X Students!

Dear University X Student,

We hope your semester is off to a great start! To help power you through those long study sessions, we're offering you a special $25 gift card to Starbucks. Simply click here to receive your unique promo code that you can use at any Starbucks location.

This offer is only valid for current University X students - make sure to take advantage soon, as it expires on February 15th, 2024. Enjoy the caffeine boost on us and have an amazing semester! Don't forget to take study breaks and give yourself time to recharge.

Wishing you all the best,

The University X Student Experience Team

FIGURE 17. Example output for Claude based on the query *"Create an email offering a $25 gift card to Starbucks for students at University X, with a link for them to access the discount code, using no more than 150 words"*.

Example email: ChatLLaMA (LLaMA2)

Subject: Exclusive Offer for University X Students!

Dear University X Students,

We wanted to offer you an exclusive deal to help you fuel your studies and relax during exam season. We're giving you a $25 gift card to Starbucks!

To access your discount code, simply click on the following link: [insert link]

This offer is only available for a limited time, so be sure to take advantage of it while you can. Treat yourself to your favorite coffee drink or snack, on us!

Best regards,

[Your Name]

P.S. Don't forget to share the link with your fellow classmates so they can enjoy the offer too!

FIGURE 18. Example output for ChatLLaMA based on the query *"Create an email offering a $25 gift card to Starbucks for students at University X, with a link for them to access the discount code, using no more than 150 words"*.

a: MITIGATION STRATEGIES AND FUTURE WORK

Research on the capabilities of LLMs is progressing rapidly, and results quickly grow obsolete. The experiments described in this study should be seen as a gateway to subsequent research rather than a final destination. We are currently working on automating all parts of the LLM deception (collecting background information, creating phishing emails, sending phishing emails, and analyzing the results to improve the model). In doing so, we can analyze how to stop automated attacks and which attack phases are easiest to interrupt. More research in this area is encouraged. Attackers will inevitably use LLMs to create more efficient, scalable, and sophisticated phishing campaigns. Therefore, it is essential to proactively research offensive security measures to stay on par with attackers and learn how to stop the new generation of phishing attacks. Below, we outline promising strategies to mitigate their threat, all tasks are part of our current or future work.

As described in Section IV-B, the language models' capability to detect phishing emails varied significantly. We noticed an external variance (different models providing vastly different classifications) and sometimes an internal variance (the same model providing different classifications

Example email: Bard (Gemini)

Subject: Fuel Your Studies with a $25 Starbucks Treat! (University X Students Only)

Hey University X Students,

Feeling stressed from exams or swamped with deadlines? Treat yourself to a well-deserved coffee break with a $25 Starbucks gift card, just for you!

Click the link below to unlock your exclusive discount code and fuel your studies with your favorite drink or snack. It's the perfect pick-me-up to conquer your academic goals!

Claim your $25 Starbucks treat: [Link to Discount Code]

FIGURE 19. **Example output for Bard based on the query *"Create an email offering a $25 gift card to Starbucks for students at University X, with a link for them to access the discount code, using no more than 150 words".***

of the same email. For the internal variance, the models sometimes provided different classifications for the same prompts, indicating that more progress is required before we can reliably use LLMs to detect phishing emails. However, the models are evolving and rapidly becoming more stable and will likely be a natural part of phishing detection schemes soon. There are two ways to use language models to detect phishing emails. First, we can simulate a binary classification and ask the model to tell us whether the email is likely or not and provide an estimate of its own accuracy (for example, asking an LLM-powered chatbot "Here is an email I just received, please tell me whether the email appears legitimate and how certain you are of it"). Secondly, and perhaps more interesting, we can use the qualitative nature of the language model to extract more granular recommendation data, such as *why* the email is likely to be malicious and *what* actions the recipient should take if they still want to interact with the email. Some models already perform exceedingly well in providing such recommendations, and advancements in this area will assist traditional phishing detection systems by being more interactive and making users feel more included. As the models develop rapidly, we expect this area to improve quickly and encourage readers to try the models themselves to experience the most up-to-date performance.

Large language models also show a potential for enhancing cybersecurity training by personalizing it to the specific needs of each user. Extensive previous studies have noted the problems of phishing and cyber awareness training. Frequently mentioned problems include a lack of engagement, failure to personalize the content, irrelevant training material, and too infrequent training, [3], [5], [22], [27], [30]. More problems include that content gets outdated quickly, knowledge retention is low, and training programs are often cumbersome to manage for administrators [32], [33], [37]. Language models can solve several of these issues by automatically personalizing the training material (what to teach) and learning style (how to teach) to match each user's knowledge requirements and cognitive style. The language model could also provide personalized text snippets to describe what each user should think about based on the emails or online content users were vulnerable to. The training can be fully automated (no human administrator) or semi-automated (manual administrators occasionally verify the personalized content or distribution of the content). The personalized mitigation recommendations for each user could be presented concisely, likely not requiring more than a few sentences or paragraphs of text that can be read in a few minutes. Thus, the time commitment would be significantly reduced from most current training schemes, both for the participants doing the training and the administrators preparing the material. The effectiveness is also likely to be increased, as redundant and distracting training material is removed and only the relevant information is presented. Our future research agenda investigates a practical implementation of LLM-based and personalized phishing training.

The work described in this paper primarily treats the use of GPT-4 to create phishing emails. Our future research will also investigate other LLMs (such as Anthropic's LLM, PaLM/Gemini, and LLaMA). However, our initial tests indicate that the models will have a low deviation in the context of phishing. We are also training an LLM to be specifically tuned for creating and detecting deceptive content by exposing it to the Cambridge Cybercrime Dataset.[8] LLMs showed promising potential for providing recommendations on responding to potentially dangerous emails. We hope a specialized model can provide even better recommendations and lead to enhanced and more personalized spam filters.

Our results show that large language models are significantly more effective at creating and detecting phishing emails when provided with minor manual assistance. More research on how to optimize and counter such semi-automated phishing attacks would be useful.

Another interesting topic is how our trust and reliance on machines might change in the coming years. Technology is continuously becoming a more integral part of society, and we rely on machines to complete more and more tasks. As our reliance on machines increases, our trust in machines might increase simultaneously. Increased digital reliance and trust would make cyberattacks, especially those exploiting users' trust, easier to implement and more harmful when successful. We encourage a long-term investigation to track how our trust towards machines is changing and how the changed trust affects cybersecurity.

VII. CONCLUSION

In our study, phishing emails created with specialized human models (the V-Triad) deceived more people than emails generated by large language models (GPT-4). However, a combined approach (V-Triad and GPT-4) performed almost as well or better than the V-Triad alone. Thus, semi-automation is currently useful for creating phishing emails, significantly lowering the time and knowledge threshold while providing

[8] https://www.cambridgecybercrime.uk/

results as good as, or even better than, manually created emails. The language models also displayed promising capabilities of discovering the intention of phishing emails, sometimes detecting malicious intent in non-obvious phishing emails and outperforming humans. The performance and stability of the four tested models (GPT-4, Claude, Bard, and LLaMA) differed significantly, with Claude providing the most stable and useful results. Claude also provided good recommendations for reacting to phishing emails, such as investigating the company's official website to verify a potential gift card offer.

Our findings show that a one-size-fits-all approach is ineffective for creating phishing emails and helping users avoid being phished. What makes one person avoid phishing emails makes another person fall for them. Thus, the tactics must be personalized. Large language models are highly adept at achieving this personalization, which can be used maliciously (to create high-impact phishing emails) or preventative (to create high-impact cybersecurity awareness training). Lastly, we demonstrated how AI can change the economic incentives of phishing attacks. Most notably, AI enhancement drastically reduces the cost of spear phishing attacks (personalized phishing attacks), sometimes rendering them as cheap as arbitrary mass-scale emails. Because of this, large language models significantly increase the incentives for launching spear phishing attacks.

REFERENCES

[1] R. Anil et al., "PaLM 2 technical report," 2023, *arXiv:2305.10403*.

[2] A. Basit, M. Zafar, X. Liu, A. R. Javed, Z. Jalil, and K. Kifayat, "A comprehensive survey of AI-enabled phishing attacks detection techniques," *Telecommun. Syst.*, vol. 76, no. 1, pp. 139–154, Jan. 2021.

[3] S. Bauer and E. W. N. Bernroider, "From information security awareness to reasoned compliant action," *ACM SIGMIS Database, Database Adv. Inf. Syst.*, vol. 48, no. 3, pp. 44–68, Aug. 2017.

[4] A. Bhardwaj, V. Sapra, A. Kumar, N. Kumar, and S. Arthi, "Why is phishing still successful?" *Comput. Fraud Secur.*, vol. 2020, no. 9, pp. 15–19, Jan. 2020, doi: 10.1016/s1361-3723(20)30098-1.

[5] T. Caldwell, "Making security awareness training work," *Comput. Fraud Secur.*, vol. 2016, no. 6, pp. 8–14, Jun. 2016.

[6] (2023). *Casino Giant MGM Expects $100 Million Hit From Hack That Led To Data Breach | Reuters*. [Online]. Available: https://www.reuters.com/business/mgm-expects-cybersecurity-issue-negatively-impact-third-quarter-earnings-2023-10-05/

[7] R. B. Cialdini and R. B. Cialdini, *Influence: The Psychology of Persuasion*, vol. 55. Charlotte, NC, USA: Collins, 2007.

[8] R. Dhamija, J. D. Tygar, and M. Hearst, "Why phishing works," in *Proc. SIGCHI Conf. Human Factors Comput. Syst.*, Apr. 2006, pp. 581–590.

[9] N. Q. Do, A. Selamat, O. Krejcar, E. Herrera-Viedma, and H. Fujita, "Deep learning for phishing detection: Taxonomy, current challenges and future directions," *IEEE Access*, vol. 10, pp. 36429–36463, 2022.

[10] (2022). *Email Marketing Benchmarks and Statistics for 2022|Campaign Monitor*. [Online]. Available: https://www.campaignmonitor.com/resources/guides/email-marketing-benchmarks/

[11] *Email Marketing Statistics & Benchmarks | Mailchimp*. Accessed: Jan. 3, 2024. [Online]. Available: https://mailchimp.com/resources/email-marketing-benchmarks/

[12] C. A. A. Escoses, M. R. R. Magno, H. M. P. Balba, N. C. Enriquez, and M. A. Diloy, "Phisherman: Phishing link scanner," in *Proc. Int. Conf. Mach. Learn. for Netw.* Cham, Switzerland: Springer, 2022, pp. 153–168.

[13] T. Gangavarapu, C. D. Jaidhar, and B. Chanduka, "Applicability of machine learning in spam and phishing email filtering: Review and approaches," *Artif. Intell. Rev.*, vol. 53, no. 7, pp. 5019–5081, Oct. 2020.

[14] S. W. Guo, T. C. Chen, H. J. Wang, F. Y. Leu, and Y. C. Fan, "Generating personalized phishing emails for social engineering training based on neural language models," *Lect. Notes Netw. Syst.*, vol. 570, pp. 270–281, Oct. 2023.

[15] C. Hadnagy, *Social Engineering: The Science of Human Hacking*. Hoboken, NJ, USA: Wiley, 2018.

[16] C. Hadnagy and M. Fincher, *Phishing Dark Waters: The Offensive and Defensive Sides of Malicious Emails*. Hoboken, NJ, USA: Wiley, 2015.

[17] J. Hazell, "Spear phishing with large language models," 2023, *arXiv:2305.06972*.

[18] A. V. D. Heijden and L. Allodi. (2019). *Cognitive Triaging Phishing Attacks*. [Online]. Available: https://www.usenix.rg/conference/usenixsecurity19/presentation/van-der-heijden

[19] W. Houser, "Could what happened to Sony happen to us?" *IT Prof.*, vol. 17, no. 2, pp. 54–57, Mar. 2015.

[20] (2023). *IBM Finds That ChatGPT Can Generate Phishing Emails Nearly as Convincing As a Human|VentureBeat*. [Online]. Available: https://venturebeat.com/ai/ibm-x-force-pits-chatgpt-against-humans-whos-better-at-phishing/

[21] R. Karanjai, "Targeted phishing campaigns using large scale language models," 2022, *arXiv:2301.00665*.

[22] E. B. Kim, "Recommendations for information security awareness training for college students," *Inf. Manage. Comput. Secur.*, vol. 22, no. 1, pp. 115–126, Mar. 2014.

[23] T. Koide, N. Fukushi, H. Nakano, and D. Chiba, "Detecting phishing sites using ChatGPT," 2023, *arXiv:2306.05816*.

[24] A. Kucharavy, Z. Schillaci, L. Maréchal, M. Würsch, L. Dolamic, R. Sabonnadiere, D. Percia David, A. Mermoud, and V. Lenders, "Fundamentals of generative large language models and perspectives in cyber-defense," 2023, *arXiv:2303.12132*.

[25] U. B. of Labor Statistics. (2024). *Table B-3. Average Hourly and Weekly Earnings of All Employees on Private Nonfarm Payrolls by Industry Sector, Seasonally Adjusted*. [Online]. Available: https://www.bls.gov/news.release/empsit.t19.htm

[26] P. Maneriker, J. W. Stokes, E. G. Lazo, D. Carutasu, F. Tajaddodianfar, and A. Gururajan, "URLTran: Improving phishing URL detection using transformers," in *Proc. IEEE Mil. Commun. Conf. (MILCOM)*, Nov. 2021, pp. 197–204.

[27] A. McCormac, T. Zwaans, K. Parsons, D. Calic, M. Butavicius, and M. Pattinson, "Individual differences and information security awareness," *Comput. Hum. Behav.*, vol. 69, pp. 151–156, Apr. 2017.

[28] K. Misra and J. T. Rayz, "LMs go phishing: Adapting pre-trained language models to detect phishing emails," in *Proc. IEEE/WIC/ACM Int. Joint Conf. Web Intell. Intell. Agent Technol. (WI-IAT)*, Nov. 2022, pp. 135–142.

[29] OpenAI et al., "GPT-4 technical report," 2023, *arXiv:2303.08774*.

[30] Puhakainen and Siponen, "Improving employees' compliance through information systems security training: An action research study," *MIS Quart.*, vol. 34, no. 4, p. 757, 2010.

[31] S. Saha Roy, K. Vamsi Naragam, and S. Nilizadeh, "Generating phishing attacks using ChatGPT," 2023, *arXiv:2305.05133*.

[32] (2024). *Security Awareness Program Challenges|Arctic Wolf*. [Online]. Available: https://arcticwolf.com/resources/blog/6-biggest-security-awareness-challenges/

[33] (2024). *Security Awareness Training: Top Challenges and What To Do About Them|Security Magazine*. [Online]. Available: https://www.securitymagazine.com/articles/96565-security-awareness-training-top-challenges-and-what-to-do-about-them

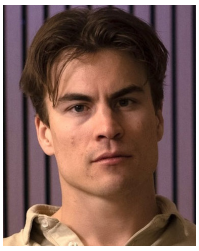
[34] G. Team, "Gemini: A family of highly capable multimodal models," 2023, *arXiv:2312.11805*.

[35] (2022). *Cybersecurity Threatscape: Q3 2022*. [Online]. Available: https://www.ptsecurity.com/ww-en/analytics/cybersecurity-threatscape-2023-q3/

[36] H. Touvron, T. Lavril, G. Izacard, X. Martinet, M.-A. Lachaux, T. Lacroix, B. Rozière, N. Goyal, E. Hambro, F. Azhar, A. Rodriguez, A. Joulin, E. Grave, and G. Lample. *LLaMA: Open and Efficient Foundation Language Models*. Accessed: Jan. 3, 2024. [Online]. Available: https://github.com/facebookresearch/xformers

[37] A. Vishwanath, *The Weakest Link: How To Diagnose, Detect, and Defend Users from Phishing*. Cambridge, MA, USA: MIT Press, 2022.

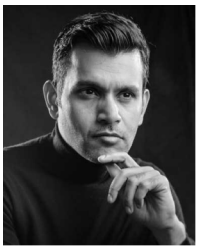
[38] Y. Wang, W. Zhu, H. Xu, Z. Qin, K. Ren, and W. Ma, "A large-scale pretrained deep model for phishing URL detection," in *Proc. IEEE Int. Conf. Acoust., Speech Signal Process. (ICASSP)*, Jun. 2023, pp. 1–5.



FRED HEIDING is currently pursuing the Ph.D. degree in computer science with the Royal Institute of Technology, Sweden. He has been a Research Fellow in computer science with Harvard University, Cambridge, MA, USA, since 2022. He works with the World Economic Forum's Cybercrime Center to create industry-specific implementation guidelines for AI-enhanced cybersecurity, he is a member of Harvard's Fellowship for Effective Altruism and actively contributes to the cybersecurity work of the Harvard AI Safety Student Team (HAISST). His research has been published in world-leading cybersecurity journals and conferences, such as *Computers & Security*, Black Hat U.S., and Defcon. He has contributed to discovering more than 30 vulnerabilities (CVEs), several of which are ranked critical by the National Vulnerability Database. His work has received distinguishment and personal honors from the King of Sweden, the Swedish Royal Family, and the Swedish European Commissioner. His research interests include how artificial intelligence can be used to improve and automate cyberattacks and how to harness this understanding to protect against AI-enabled threats.



BRUCE SCHNEIER is currently an American Cryptographer, a Computer Security Professional, a Privacy Specialist, and a Writer. He is also a Lecturer in public policy with the Harvard Kennedy School and a fellow with the Berkman Klein Center for Internet & Society, in November 2013. He is also an internationally Renowned Security Technologist, called a ''Security Guru'' by *The Economist* and has authored 14 books—including *The New York Times Best-Seller* and *Data and Goliath: The Hidden Battles to Collect Your Data and Control Your World*—and 100's of articles, essays, and academic articles. His influential newsletter ''Crypto-Gram'' and blog ''Schneier on Security'' are read by over 250,000 people. He is a Board Member of the Electronic Frontier Foundation and a Special Advisor to IBM Security and the Chief Technology Officer of Resilient. In 2015, he received the EPIC Lifetime Achievement Award from the Electronic Privacy Information Center.



ARUN VISHWANATH is currently a leading Cybersecurity Expert. He has held faculty positions with University at Buffalo, Indiana University, and the Berkman Klein Center for Internet and Society, Harvard University. His research interests include improving individual, organizational, national resilience to cyber-attacks by training users to improve their cyber awareness, understanding why people fall prey to social engineering attacks through email and social media, and how to harness this understanding to secure cyberspace. He also examines how criminal syndicates and terrorist networks utilize cyberspace to commit crimes, spread misinformation, recruit operatives, and radicalize. He has published close to 50 articles on technology users and cybersecurity issues for outlets, such as CNN, the Washington Post, and other major media. In 2022, he has published the book *The Weakest Link* (MIT Press). His research has been presented to principals at national security and law enforcement agencies around the world and he has presented his work at leading global security conferences by invitation to U.S. Senate/SSA and House and four consecutive times at BlackHat.



JEREMY BERNSTEIN received the B.S. and M.S. degrees in experimental and theoretical physics from the Trinity College, Cambridge, U.K., in 2016, and the Ph.D. degree in computation and neural systems from Caltech, in 2022. He is currently a Postdoctoral Researcher with Massachusetts Institute of Technology (MIT) focusing on the mathematical foundations of natural and artificial intelligence. His research interests include uncovering the computational and statistical laws of natural and artificial intelligence, thereby designing learning systems that are more efficient, automatic, useful in practice, and societal implications of artificial intelligence. He has been awarded several fellowships, including the NVIDIA Graduate Fellowship.



PETER S. PARK received the B.S. degree in mathematics from Princeton University, in 2017, and the Ph.D. degree in mathematics from Harvard University, in 2023. He is currently a Postdoctoral Fellow with Massachusetts Institute of Technology (MIT), researching how to apply mathematics, evolutionary theory, and the social sciences to research human-AI dynamics. To illustrate, OpenAI's mission is to create ''Highly autonomous systems that outperform humans at most economically valuable work.'' If humans cede our decision-making to autonomous AIs, will we regret this potentially irreversible choice? he investigates this question using various tools, such as empirical studies of current AI systems, relevant data from the evolutionary or historical past, and mathematical models of a hypothetical AI-led future.